Ecole Supérieure d'Informatique et du Numérique
COLLEGE OF ENGINEERING & ARCHITECTURE

Introduction to Cybersecurity

NETWORK SECURITY

PRESENTED BY:
SEBBAR ANASS

Année universitaire: 2025-2026

1

1

Lecture: Introduction To CyberSecurity

Sebbar Anass, PhD in CS&S

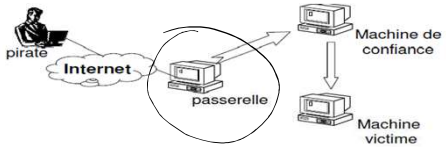
Email : anass.sebbar@uir.ac.ma
Office Location: Building 7, 4th Floor, Room B405

Coordinator of the Cybersecurity Track:

2

Vulnérabilités courantes

- TCP/IP protocol

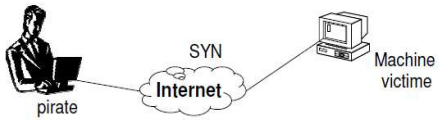


- **IPSpoofing: Establishing communication with the victim machine by pretending to be the trusted machine (by creating a fake message artificially containing the source address of the trusted machine)**

3

SYN flooding

sends a TCP packet with the armed SYN flag that appears to come from an unreachable, turned off, or non-existent machine. The victim machine therefore sends the second packet for the opening of the connection and waits for the response from the non-accessible machine, which never comes. (connection monopolization)

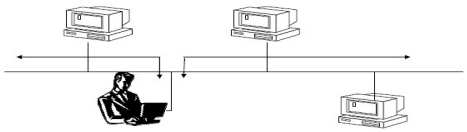


4

4

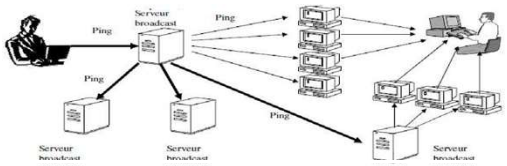
Sniffing

- Sniffing: Capturing all the information from the machines on the network passing through the machine in question. It allows traffic to be analyzed for passwords and sensitive data.



5

ICMP Protocol: Ping



Attaque par réflexion (Smurfing Attacks) :
(1) retrieving the target's IP address by spoofing;
(2) Pinging multiple broadcast servers by changing the source address to that of the victim machine.
(3) Broadcast servers address all machines on their networks;
(4) The victim machine will receive as many pings as there are machines on the broadcast server networks and will eventually lose all of its bandwidth

6

UDP Protocol: UDP Flood

In the same way as with SYN Flooding, the attacker sends a large number of UDP requests to a machine.
UDP traffic takes precedence over TCP traffic. This type of attack can quickly disrupt and overwhelm the traffic passing through the network.

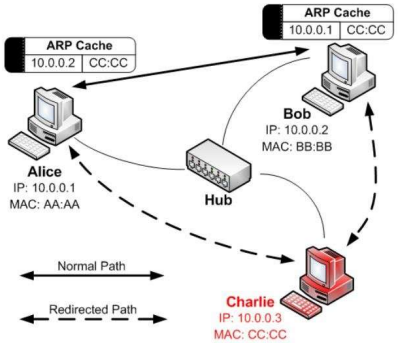
7

ARP Protocol: ARP Spoofing

Is to assign the @IP of the target machine, by matching its @IP to the @ MAC of the hacker machine in the ARP tables of the machines on the network. (Regular sending of ARP_reply packets in broadcast, containing the target @IP and the fake MAC address. This has the effect of changing the dynamic tables of all machines in the network. They will send their Ethernet frames to the hacker machine while believing they are communicating with the target

8

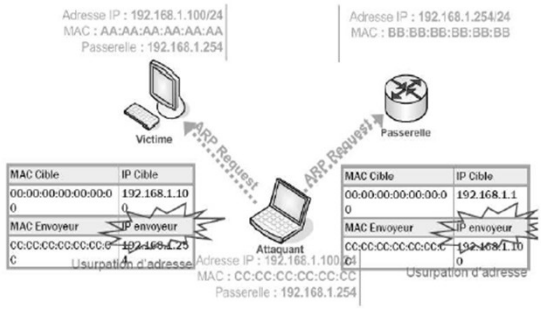
ARP Protocol: ARP Spoofing



9

9

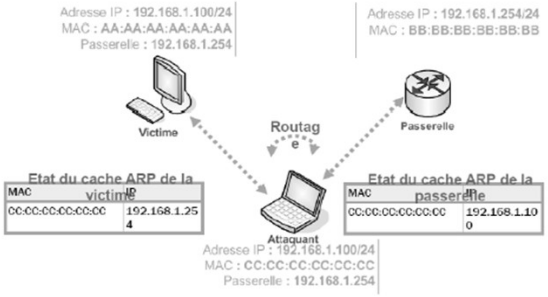
ARP Poisoning



10

10

ARP Poisoning + routage



11

11

Service messagerie: SMTP

- **Mail Bombing:** consists of sending a large number of emails with files attached (several thousand for example) to one or more recipients
- **Spamming:** Sending several identical emails (often advertising-type) to a large number of people on the network. The primary purpose of spamming is to advertise at a lower cost

12

Service Web: HTTP

- **Cookies: information that allows servers to recognize any visitor who has already logged in to this service. This information can be used by a hacker or by commercial sites.**
- **JavaScript** : Various security vulnerabilities due to errors in the foragers are detected:
  - Relire des informations du disque dur de l'utilisateur et retransmettre l'information vers un autre site du réseau
  - retransmit the user's e-mail address, as well as the addresses of visited documents
  - Spy on the pages that the user will visit later
- **Java applets or ActiveX components**

13

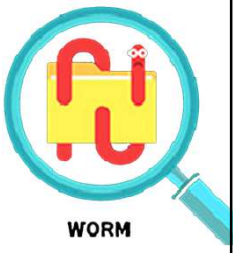
Viruses

- **Boot viruses:** replace the bootstrap of a disk with their own code, and then load into central memory.
- **Virus Program:** add their source code to the program in EXE, COM, BAT, they destroy the file, and load into central memory.
- **Macro viruses:** are found in files that use macro commands, such as Word, Excel, etc. When the macro is launched, the virus will be in action.
- **Partition viruses:** lodge in the partition table, and do not need an infected file to be loaded into memory
- **Bounty hunters:** directly target antiviruses by modifying them to make them impotent, this kind of virus is very rare but very effective.

14

Worms

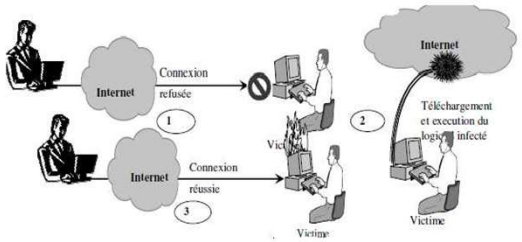
- cannot be grafted onto another program and therefore infect it, it is copied via a network or the Internet, from computer to computer.
- Replication
  ==>
  - ✓Assign a computer
  - ✓Degrade network performance

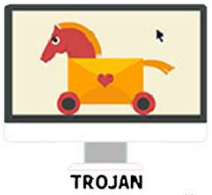


15

Horses of three

Malicious program or code that does something else in addition to its stated function





16

Les logiciels d'espionnage (Spyware)

- A tool infected with spyware can pose a very big threat to the security of the infected information system.
- Indeed, several successive routines can allow the detection of encrypted passwords and the cracking of this information

17

Top application vulnerabilities and malware activity

Top 5 Application Vulnerabilities / IPS

Rank	Name	%
1	Generic.XXE.Detection	21
2	TCP.Split.Handshake	20
3	PHPUnit.Eval-stdin.PHP.Remote.Code.Execution	20
4	D-Link.Devices.HNAP.SOAPAction-Header.Command.Execution	20
5	ThinkPHP.Controller.Parameter.Remote.Code.Execution	19

Newly Disclosed Vulnerability in Apache Commons Text Allows for RCE (CVE-2022-42889) – FortiGuard Labs is aware of reports that reveal a recent vulnerability in Apache Commons, assigned CVE-2022-42889, that allows remote code execution. Apache Commons Text prior to 1.10.0 allows remote code execution (RCE) when applied to untrusted input from insecure interpolation defaults.

What are the details of this vulnerability? According to Apache, version 1.5 and 1.9 of Apache Commons are affected. Apache Commons suffers from default Lookup instances where interpolators that have been included could result in arbitrary code execution or contact with remote servers. These lookups are - "script" - execute expressions using the JVM script execution engine (javax.script) - "dns" - resolve dns records - "url" - load values from urls, as well as those from remote servers. Applications using the defaults in versions 1.5 and 1.9 may be vulnerable to remote code execution, or unintentional contact with remote servers, if untrusted configuration values are used. Users are recommended to upgrade to Apache Commons Text 1.10.0, which disables the default interpolators.

Signatures:
Apache.Commons.Text.Interpolation.Remote.Code.Execution (default action is set to "pass")

Top 5 Malware Activity

Rank	Name	%
1	W32/Alllu.A!tr	34
2	W32/Hrup!tr	20
3	W32/VBNA.HLT!worm	16
4	W32/Inject.ZYD!tr	16
5	W32/Flystud.RN!tr	14

Outbreak Alert: Prestige Ransomware – FortiGuard Labs is aware of a report published about a new ransomware strain called Prestige that is being distributed in an attack campaign targeting Ukraine and Poland. The ransomware encrypts files on a compromised machine and adds a ".enc" file extension to the affected files.

This is significant because Prestige ransomware is one of the few ransomware strains being distributed to Ukraine, as well as Poland, a known ally of Ukraine.

Prestige Ransomware has deployment techniques similar to the ones recently used in destructive attacks leveraging AprilAxe (ArguePatch)/CaddyWiper or Foxblade (HermeticWiper).

18

Operating System Vulnerability

- Software (operating systems and applications) almost all come with errors. These errors are often benign, but sometimes they can create security holes in our system that can be used by bad actors to attack it

19

Tools for attacking and analyzing computer network traffic

- Analyseurs de trames (sniffer) tcpdump:
  analyseur en mode texte
  wireshark: analyseur en mode graphique
  tshark: comme wireshark mais en mode texte
  dsniff: recherche de mode passe
- Balayeur de ports (scanner) telnet: scanner de port du pauvre nmap: scanner de ports …
- Détecteurs d'intrusion (IDS) snort, chkrootkit, portsentry

20

Tcpdump

- Tcpdump [options] [expression]
- Options:

-i interface
-w fichier: stocke le résultat dans le fichier
-F fichier :expression de filtrage est lue à partir du fichier
-n : ne pas convertir les adresses en noms
-a : convertit les adresse en nom
-N: n'affiche pas le nom de domaine des machine
-c n: s'arrete après n paquets
-v : plus de detail (TTL, ToS ...)
-vv: mode plus verbeux
-e: affiche les donnée en couche liaison (adress MAC)
-s n: concerve/affiche les n premiers octets d'un paquet
-S: affiche les numéros de séquences TCP

- Expressions:

Les quantificateurs de type: host, net, port
Les quantificateurs de direction: src, dst, src and dst, src or dst, src net, dst port ...
Les quantificateurs de protocole: ether, fddi, ip, icmp, arp, rarp, tcp, udp, ip proto ...
Les quantificateurs spéciaux: broadcast, gateway, less, greater, not (ou !), or (ou ||), and (ou &&), <,>,<=, <=, <> ,=, !=

example

- $tcpdump

// capture sur la sortie standard

- $tcpdump –i eth0 –w fichier

//visualiser les paquets web

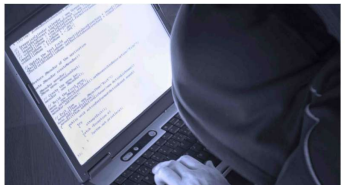
- $tcpdump tcp port 80
- $tcpdump host 192.168.1.23
- $tcpdump ip proto 1 ⇔ $tcpdump icmp
- $tcpdump 'tcp and (port 21 or port 80)'

Buts de la Security – Extensions du Modèle CIA

- According to some experts, 2 properties should be added to the CIA model
- Authenticity
  - The author of the information must be clear
    - This implies that the information has not been modified since the author generated it.
    - Authenticity is stronger than integrity
- Accountability
  - The actions of an entity can be traced only to that entity

Défendre est Difficile

- The weakest link
  - The attacker needs to find a **single** flaw
  - The defendant must defend against **all** flaws
- Users
  - Ne sont pas forcément motivés pour suivre les règles
  - Ne sont pas des experts
- Compromis entre Security, performance et usabilité
  - On ne sait pas produire des systèmes avec les 3 propriétés

Attention

- Attacking doesn't mean you're a genius
- Attacking can make us a criminal
- Attacks can be prosecuted in law